DOCUMENT CONTROL PAGE

Field	Details
Document Title	Third Party &Vendor Management Policy
Document ID	CIL-ISMS-TPVM-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 5(Organizational Controls) & 8(Technological Controls)
Control Reference/Sub-Domain	5.19, 5.20, 5.21, 5.22, 5.23, 8.8, 8.9, 8.32
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	Security Engineering Lead
Reviewer(s)	Legal & Compliance Officer, Data Protection Officer, SOC Manager, DevSecOps Lead, IT Infrasturcture Mangager
Classification	Confidential - Internal Use Only
Distribution	All employees, Contractors, Third Parties(where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____

For: Cyberinfiniti Ltd

Third Party &Vendor Management Policy

1. Organisational Context

Given the nature of our operations, CyberInfiniti Ltd processes sensitive assets including client data, threat intelligence, security configurations, cloud-hosted applications, and personal data governed by the **Nigeria Data Protection Act 2023**.

Third-party relationships introduce risks such as unauthorized access, data breaches, service disruption, and regulatory non-compliance. This policy establishes a structured framework to ensure that supplier engagements do not compromise the confidentiality, integrity, and availability of information assets, while maintaining client trust and regulatory alignment.

2. Purpose

The purpose of this policy is to ensure that all third-party and vendor relationships are governed in a secure, risk-based, and compliant manner.

CyberInfiniti Ltd is committed to:

- Ensuring suppliers meet defined security and compliance standards
- Conducting due diligence prior to onboarding vendors
- Enforcing contractual security and data protection obligations
- Monitoring supplier performance and security posture continuously
- Managing supplier risks throughout the lifecycle

This policy aligns with **ISO/IEC 27002:2022** controls 5.19–5.23 on information security in supplier relationships.

3. Scope

This policy applies to:

- All third-party vendors, suppliers, contractors, consultants, and partners
- All employees and departments managing supplier relationships
- All systems, services, and data accessed or managed by suppliers

Vendors with no access to sensitive systems or data (e.g., facilities or construction vendors) are generally out of scope unless specified otherwise.

4. Governance & Roles

Supplier security is governed through clearly defined roles:

- **Executive Management:** Approves high-risk engagements and ensures oversight
- **CISO:** Owns the policy, conducts risk assessments, and ensures compliance
- **Procurement Team:** Embeds security requirements into contracts
- **IT/Technical Team:** Manages access and validates technical controls
- **Legal & Compliance:** Ensures regulatory and contractual alignment
- **Contract Owners:** Manage supplier relationships and performance
- **Suppliers:** Must comply with all CyberInfiniti security requirements

This structure ensures accountability and consistent enforcement across the supplier lifecycle.

5. Vendor Risk Management Framework

Suppliers are classified based on risk exposure:

- **Critical:** Direct access to sensitive data or production systems (reviewed quarterly)
- **High:** Access to regulated or non-production systems (bi-annual review)
- **Medium:** Limited or indirect access (annual review)
- **Low:** No system or sensitive data access (light annual review)

Risk classification determines the level of due diligence, monitoring, and control enforcement applied.

6. Policy Requirements

6.1 Supplier Due Diligence

All suppliers must undergo security assessment prior to onboarding. High-risk vendors must demonstrate strong security controls (e.g., ISO certifications or audit reports).

6.2 Contractual Security Controls

Supplier agreements must include:

- Confidentiality and data protection clauses
- Incident reporting obligations
- Defined SLAs and security controls
- Right-to-audit provisions

6.3 Access Management

- Supplier access must follow least privilege principles
- Access must be reviewed regularly
- Access must be revoked immediately upon termination

6.4 Monitoring & Review

- Supplier performance and compliance are reviewed periodically
- Changes in supplier services must undergo security impact assessment

6.5 Incident Management

Suppliers must:

- Report incidents within 24 hours
- Support investigations and remediation
- Provide root cause analysis

6.6 Supplier Termination

Upon termination:

- All access is revoked
- Data must be returned or securely deleted
- Exit procedures must be formally completed

7. Compliance & Regulatory Alignment

This policy supports compliance with:

- **General Data Protection Regulation (GDPR) / NDPR** – Protection of personal data
- **ISO/IEC 27001 & ISO/IEC 27002** – Supplier security governance
- **NIST Cybersecurity Framework** – Supply chain risk management
- **CIS Controls v8** – Service provider management

8. Monitoring, Enforcement & Metrics

Compliance is enforced through:

- Supplier audits and security assessments
- Access reviews and vendor monitoring
- Tracking of incidents and SLA adherence
- Maintenance of a vendor risk register

Key metrics include:

- Supplier audit results
- Incident frequency and response times
- SLA compliance rates

- Risk rating updates

Non-compliance may result in:

- Access revocation
- Contract suspension or termination
- Disciplinary or legal action

9. Exceptions & Governance Control

Exceptions must:

- Be formally documented
- Undergo risk assessment
- Receive executive approval
- Include defined validity and review timelines

10. Continuous Improvement

CyberInfiniti Ltd is committed to continuously improving supplier security governance through:

- Periodic audits and reviews
- Lessons learned from incidents
- Regulatory updates
- Evolving threat intelligence

Executive Statement

CyberInfiniti Ltd recognizes that third-party risk is a critical component of cybersecurity governance. Through structured supplier management aligned with ISO standards and global best practices, the organization ensures that all vendor relationships support secure, resilient, and compliant operations.

1. ORGANISATIONAL CONTEXT

CyberInfiniti Ltd is a cybersecurity startup providing:

- Managed Security Services (MSSP)
- Penetration Testing & Red Team Services
- SOC Monitoring Services
- Governance, Risk & Compliance Advisory
- Cloud & Infrastructure Security Consulting
- Cybersecurity Training & Academy Portal

As a cybersecurity organization handling:

- Client-sensitive information
- Threat intelligence data
- Security tooling configurations
- Cloud-hosted applications
- Personal data under NDPA 2023

CyberInfiniti must maintain a robust vulnerability management and secure testing framework to protect:

- Confidentiality
- Integrity
- Availability
- Regulatory compliance
- Client trust

1. Purpose

The purpose of this policy is to ensure Cyberinfiniti LTD manages third-party and vendor relationships in a way that protects the confidentiality, integrity, and availability of information assets. The policy follows the guidance and control requirements of ISO 27002:2022, specifically sections 5.19-5.23 on “Information Security in Supplier Relationships.” Cyberinfiniti LTD is committed to:

- Ensuring third-party vendors meet Cyberinfiniti LTD standards for privacy, security, and compliance.

- Conducting appropriate due diligence before granting vendors access to sensitive or protected institutional data.
- Requiring necessary legal agreements and security assessments based on the data classification involved.
- Involving the Information Services division in vendor-related decisions involving data or data systems.
- Monitoring vendors for ongoing compliance, incident response readiness, and risk management.

2. Scope

This policy applies to:

- All third-party suppliers, vendors, consultants, contractors, cloud service providers, and partners who process, store, transmit, or access Cyberinfiniti LTD's data.
- All employees, contractors, and departments initiating, managing, or interacting with vendor relationships.
- All systems, data, and services provided to or managed by suppliers.
- Vendors providing only goods or services without access to sensitive institutional data or systems (e.g., construction vendors, facilities maintenance) are outside the scope of this policy unless otherwise specified in a contract.

3. Roles and Responsibilities

Role	Responsibilities
Executive Management	Approves policy and critical supplier engagements; ensures adequate resources for supplier security management.
Chief Information Security Officer (Policy Owner)	Conducts due diligence, risk assessments, and security reviews; ensures supplier compliance with ISO 27002 controls; oversees monitoring and audits.
Procurement / Administrative Team	Ensures contracts include required security clauses; coordinates onboarding and renewal processes.
IT Manager / Technical Team	Manages supplier system access; enforces least privilege; performs technical reviews and validates security controls.

Legal & Compliance Officer	Ensures supplier contracts meet regulatory, legal, and privacy requirements (GDPR/NDPR).
Department / Contract Owner	Manages day-to-day supplier relationships; monitors performance and SLAs; escalates risks or non-compliance.
Suppliers / Vendors	Comply with Cyberinfinity security requirements; report incidents; maintain contractual security controls.

4. Vendor Risk Classification & Assessment

Risk rating determines control depth, oversight, and review frequency.

Rating	Description	Examples	Review Frequency
Critical	Direct access to production systems, sensitive data, or core business	Cloud providers, SOC services, SIEM platforms	Quarterly
High	Access to non-production systems or regulated data	Marketing SaaS, payment vendors	Bi-Annual
Medium	Limited data processing or indirect access	HR platforms, admin tools	Annual
Low	No access to systems or sensitive data	Office supplies, hardware resellers	Annual (light)

5. Policy Statements

5.1 Supplier Selection & Due Diligence

- All new suppliers must undergo a formal security due diligence assessment before onboarding.
- Suppliers shall be risk-rated as Critical, High, Medium, or Low based on data sensitivity and access level.
- High-risk and critical suppliers must demonstrate an acceptable security posture (e.g., ISO 27001, SOC 2 reports).

ISO 27002 Mapping: 5.19 - Information Security in Supplier Relationships.

5.2 Contractual Security Requirements

- All supplier agreements must include security, confidentiality, data protection, incident reporting, and audit clauses.
- Contracts must specify required security controls, SLAs, the right to audit, breach-notification timelines, and subcontractor restrictions.

ISO 27002 Mapping: 5.20 - Addressing Security within Supplier Agreements.

5.3 Supplier Access Management

- Access shall be limited to the minimum required (least privilege).
- Supplier accounts will be monitored and reviewed quarterly.
- Access must be immediately revoked upon contract termination or when no longer required.

ISO 27002 Mapping: 5.21 - Managing Information Security in Supplier Relationships.

5.4 Ongoing Monitoring & Performance Review

- Supplier performance, security compliance, and SLAs must be reviewed periodically (quarterly for critical; annually for others).
- Any change in supplier service, location, or scope must go through a security impact assessment.

ISO 27002 Mapping: 5.22 - Monitoring and Review of Supplier Services.

5.5 Incident Management

- Suppliers must report security incidents affecting Cyberinfiniti LTD within 24 hours.
- Suppliers must support investigations, provide root cause analysis, and implement corrective actions.

ISO 27002 Mapping: 5.24 - Information Security Incident Management.

5.6 Supplier Termination

- Upon contract end, suppliers must securely delete or return all Cyberinfinity data.
- All access rights must be revoked.
- The Contract Owner must complete a service termination checklist.

ISO 27002 Mapping: 5.23 - Terminating or Changing Supplier Services.

6. Compliance Requirements

This policy aligns with the following standards and regulations:

- GDPR / NDPR: Data protection obligations for suppliers processing personal data.
- ISO/IEC 27001 & ISO/IEC 27002 (Controls 5.19-5.23): Supplier relationship security requirements.
- NIST Cybersecurity Framework: “Supply Chain Risk Management” function.
- CIS Controls v8: Control 15: “Service Provider Management.”

7. Enforcement and Exceptions

Enforcement:

Non-compliance with this policy may result in:

- Revocation of access privileges
- Suspension of supplier engagement
- Contract termination
- Internal disciplinary action for employees in violation

Exceptions:

Exception requests must:

- Be documented and justified.
- Undergo a risk assessment by the Information Security Manager.
- Be approved by Executive Management.

8. Definitions and References

Definitions

Term	Meaning
Supplier / Vendor	An external entity providing services, access, or products.
Critical Supplier	A vendor whose failure impacts business operations or security.
Sensitive Data	Any confidential, regulated, or internal data requiring protection.
Due Diligence	Security assessments conducted before onboarding a vendor.
Least Privilege	Access is limited to the minimum needed to perform duties.

References

- ISO/IEC 27002:2022 (Controls 5.19-5.23)
- ISO/IEC 27001:2022
- NDPR
- GDPR
- NIST CSF
- CIS Controls v8
- Related Cyberinfiniti policies: Access Control Policy, Data Protection Policy, Incident Response Policy.

9. Verification and Metrics

The effectiveness of this policy will be measured using:

- Annual supplier security audits
- Quarterly access reviews

- Tracking of supplier incidents and SLA compliance
- Review of risk ratings in the vendor register
- User awareness and training completion rate